

Stoquify blocker and gate control plane — phased implementation plan

G1 technical remediation, authentic approval requirements, and controlled next steps

BLOCKER AND GATE CONTROL REPORT

Prepared 2026-08-18

Evidence-bound | approval-gated | fail-closed

No production claim without authentic evidence.

Prepared: 2026-08-18 Implementation status: not started by this design run Initial scope: G1 pilot extending Workflow Assurance

Delivery strategy

Build the capability as an additive extension of the existing Assurance module. Keep the current G1 JSON contract, register and fail-closed scripts operational until the runtime workflow produces equivalent or stronger evidence and an independent comparison passes.

Use observe mode first. Do not enable gate enforcement from the new runtime models until G1 import, approval, verification, drift and rollback tests pass and the governance roster is approved.

Phase 0 — terminology, ownership and authoritative-source freeze

Scope

- 1 Approve canonical definitions for identity, access role, authority, delegation, qualification, approval, attestation, evidence, verification, certification, blocker, gate and waiver.
- 1 Name the organizational owner for authority data.
- 1 Define accepted appointment and qualification evidence.
- 1 Confirm the G1 role codes and segregation-of-duties matrix.
- 1 Decide retention, redaction and external-signature requirements.

Dependencies

- 1 HR/security/governance participation.
- 1 Product, finance, POS, risk, operations and qualified Cameroon/accounting reviewer input.

Schema/API/UI impact

None. Produce signed-off policy artifacts only.

Tests and evidence

- 1 Policy consistency review.
- 1 G1 decision-to-role count must equal 33.
- 1 No ambiguous role label may become an authority code.
- 1 Evidence: authority-source decision, SoD matrix, retention decision and qualification rules.

Rollback

Supersede draft policy artifacts; no runtime state exists.

Risks

- 1 Governance delay.
- 1 One person holding incompatible roles.
- 1 Unavailable qualified reviewer.

Exit criteria

- 1 Authority data owner is named.
- 1 Role-code and delegation policies are approved.
- 1 G1 qualified-review requirements are explicit.

- 1 Unresolved names remain open; no placeholder is treated as authoritative.

Phase 1 — G1 authority, artifact and evidence-envelope pilot

Scope

- 1 Add the general authority/delegation registry.
- 1 Add artifact/version/digest records.
- 1 Import the exact G1 artifact and verify its current SHA-256.
- 1 Add versioned G1 decision policy and 33 role obligations.
- 1 Add approval request/entry, authentication attestation and evidence envelope.
- 1 Keep the existing gate script as the final comparison boundary.

Dependencies

- 1 Phase 0 decisions.
- 1 Existing `requireFreshAuth`, `protect`, business events and assurance persistence.

Schema impact

Additive tables only. No existing evidence or approval rows are rewritten. Use tenant-safe composite keys, `onDelete: Restrict` for evidence relationships and explicit supersession.

APIs/events

- 1 Authority read/manage actions.
- 1 Artifact register/freeze/read actions.
- 1 Policy import/read actions.
- 1 Approval-request and decision actions.
- 1 `control.authority.*`, `control.artifact.*`, `control.approval.*` events.

UI

- 1 G1 authority roster view.
- 1 G1 obligations and approval inbox.
- 1 Exact contract/decision review view.
- 1 Evidence receipt view.

Required tests

- 1 Cross-tenant denial.
- 1 Authority missing/expired/revoked/conflicted.
- 1 Fresh-authentication expiry and tenant mismatch.
- 1 Server-side canonical payload and digest.
- 1 Replay/idempotency conflict.
- 1 Same-user incompatible-role denial.
- 1 Artifact drift invalidation.
- 1 Transaction rollback when audit/event write fails.

- 1 Accessible keyboard and screen-reader approval flow.

Migration/backfill

- 1 Register only the G1 frozen artifact and policy.
- 1 Do not backfill handwritten images as approvals.
- 1 Candidate identities may be imported only as unresolved references, not authority assignments.

Rollback

- 1 Disable the pilot feature flag and continue using the existing detached register.
- 1 Preserve new append-only evidence for audit; do not delete it.
- 1 No gate consumes runtime approval evidence until Phase 2 comparison passes.

Exit criteria

- 1 Exact G1 artifact hash is reproducible.
- 1 Policy deterministically produces 11 decisions and 33 obligations.
- 1 A test tenant can complete authenticated approvals with immutable envelopes.
- 1 No agent or unauthorized role can approve.
- 1 Current production authorization remains false.

Phase 2 — independent verifier and G1 gate integration

Scope

- 1 Add deterministic approval verification.
- 1 Add automated and human-checker verification classes.
- 1 Generate a verified G1 approval manifest from runtime records.
- 1 Compare generated manifest against the existing contract gate.
- 1 Add source-drift and downstream invalidation.

Dependencies

- 1 Phase 1 data and workflows.
- 1 Approved verifier separation policy.

APIs/events

- 1 `verifyApprovalRequest` and `invalidateControlEvidence`.
- 1 `control.verification.completed` and invalidation events.
- 1 Read-only verified-manifest exporter for the G1 gate.

UI

- 1 Verification queue and reason codes.
- 1 Side-by-side source/policy/artifact digest display.
- 1 Human-checker action only where required.

Required tests

- 1 All 33 obligations complete.
- 1 Missing role, wrong option, wrong hash and expired authority.
- 1 Producer/verifier conflict.
- 1 Artifact/policy/authority invalidation propagation.
- 1 Generated manifest equals expected contract schema.
- 1 G1 remains blocked for any unverified entry.

Rollback

- 1 Stop exporting the runtime manifest.
- 1 Revert gate adapter to the existing detached-register input.
- 1 Preserve verification history.

Exit criteria

- 1 Runtime manifest and independent verifier agree.
- 1 The G1 gate accepts only verified evidence bound to the exact contract hash.
- 1 A deliberately corrupted entry is rejected with a deterministic reason.
- 1 Passing G1 is possible only after authentic human approvals.

Phase 3 — persistent gate composition and blocker integration

Scope

- 1 Add versioned gate definitions, dependencies and composite gate runs.
- 1 Map failures to existing Workflow Assurance incidents.
- 1 Add explicit NOT_EVALUATED dependency behavior.
- 1 Preserve the current repository gates as adapters during transition.

Dependencies

- 1 Phase 2 verifier.
- 1 Gate-policy owner review.

Tests

- 1 Dependency graph cycle rejection.
- 1 Exact gate-version input manifest.
- 1 Downstream invalidation.
- 1 Idempotent rerun and changed-input conflict.
- 1 Blocker open/reopen/resolve behavior.
- 1 Waiver policy and expiry behavior.

Rollback

- 1 Keep composite gates in observe mode.
- 1 Continue existing script gates while parity is measured.

Exit criteria

- 1 G1 and G2 dependency behavior matches current scripts.
- 1 No blocked dependency is reported as passed.
- 1 Every blocker has an owner, source digest and next action.

Phase 4 — operational UI, notifications and exports

Scope

- 1 Extend Assurance Control Tower.
- 1 Add authority workbench, approvals inbox, artifact view, verification queue and gate graph.
- 1 Add redacted alerts, reminders and escalation.
- 1 Add controlled JSON/PDF evidence exports.

Dependencies

- 1 Stable Phase 1–3 contracts.
- 1 EN/FR content and accessibility review.

Tests

- 1 Permission matrix and hidden-sensitive-data tests.
- 1 Empty/loading/error/stale/expired/superseded states.
- 1 Keyboard, focus, labels, announcements and contrast.
- 1 Bilingual terminology consistency.
- 1 Alert dedupe, retry and dead-letter recovery.
- 1 Export digest verification and redaction.

Rollback

- 1 Hide new surfaces behind feature flags; service evidence remains available.

Exit criteria

- 1 Authorized users can understand and act on every G1 blocker without raw JSON editing.
- 1 Unauthorized users cannot infer sensitive approval or identity details.

Phase 5 — domain adoption

Scope

Adopt one domain at a time:

- 1 destructive migrations;
- 2 country-pack reviews;
- 3 accounting close/reconciliation;
- 4 payment/treasury releases;
- 5 inventory adjustments and purchasing/AP;
- 6 payroll/compensation;
- 7 module and AI-agent activation;

- 8 production release/rollback.

Rules

- 1 Each domain keeps its own service and data truth.
- 1 Add an evidence adapter and versioned policy, not cross-domain direct queries.
- 1 Demonstrate parity with the existing domain workflow before enforcement.
- 1 Never weaken an existing domain maker-checker or qualification requirement.

Exit criteria per domain

- 1 Owner-approved source map.
- 1 Tenant/RBAC/privacy review.
- 1 Adapter contract and failure behavior tested.
- 1 Historical evidence migration explicitly classified.
- 1 Observe-mode parity measured.
- 1 Enforce-mode decision separately approved.

Phase 6 — optional external e-signature integration

Scope

- 1 Provider-neutral adapter contract.
- 1 Signed webhook intake, provider signer mapping and final artifact/audit digest.
- 1 Evidence-envelope link to external signature evidence.

Dependencies

- 1 Legal/governance determination that a workflow requires external signature evidence.
- 1 Provider security, privacy, residency and availability review.

Tests

- 1 Provider webhook signature and replay protection.
- 1 Incorrect signer/role mapping.
- 1 Cancelled/expired envelope.
- 1 Provider outage and delayed completion.
- 1 Audit-certificate/final-document hash mismatch.

Rollback

- 1 Disable provider adapter; internal operational approvals continue where policy permits.

Exit criteria

- 1 External evidence strengthens rather than bypasses Stoquify authority and policy checks.
- 1 No provider-specific field leaks into the core approval contract.

Phase 7 — enterprise hardening and rollout

Scope

- 1 PostgreSQL integration and concurrency tests.
- 1 Chaos and recovery testing.
- 1 Backup/restore and evidence reconciliation.
- 1 Capacity, latency and cost baselines.
- 1 Security review, threat-model closure and penetration testing.
- 1 Operating procedures, training and support rollout.

Chaos cases

- 1 Database commit succeeds but notification delivery fails.
- 1 Outbox worker restarts after lease acquisition.
- 1 Authority source becomes unavailable mid-request.
- 1 Artifact storage returns stale or different bytes.
- 1 Verifier is delayed or duplicated.
- 1 External provider sends repeated/out-of-order webhooks.
- 1 Clock skew causes future or stale authentication timestamps.
- 1 Restore contains approval entries but missing export objects.

Exit criteria

- 1 No evidence loss under tested recovery cases.
- 1 Reconciliation identifies and repairs incomplete projections without inventing approvals.
- 1 Alerting and runbooks are operational.
- 1 Enforcement rollout is approved per domain and tenant cohort.

Prioritized build backlog

BG-00	Governance terminology and authority-source ADR in docs/blockers-and-gates/	None	Authority, delegation, qualification and SoD rules approved	Review record and policy digest	Supersede draft	M	Yes
BG-01	Shared canonicalization/digest contract under services/assurance/artifacts/	BG-00	Binary/JSON profiles versioned; independent recomputation matches G1	Golden vectors, drift and malformed-input tests	Feature flag; retain existing hash helpers	M	No
BG-02	Additive Prisma models/migration for artifact, authority, policy, approvals, attestation, envelope and verification	BG-00/BG-01	Schema valid; tenant-safe keys; evidence relationships restricted	Migration tests, rollback plan, data classification	Migration down-plan only before live data; otherwise disable feature	L	Yes, schema review
BG-03	Authority/delegation services and actions under services/assurance/authority/	BG-02	Active scoped assignment required; conflicts/expiry visible	Cross-tenant, revocation, delegation, SoD and fresh-auth tests	Disable management actions; preserve records	L	Yes, real assignments
BG-04	Artifact registry and G1 import adapter under services/assurance/artifacts/	BG-01/BG-02	Exact contract digest verified; frozen version immutable	G1 golden hash, path/URI boundary, drift tests	Keep current file-based gate	M	Domain owner freezes import
BG-05	Decision/policy catalog under services/assurance/policies/	BG-02/BG-04	D-01–D-11 import produces exactly 33 obligations	Policy digest, cycle/duplicate/role tests	Supersede unpublished version	L	Yes, policy approval
BG-06	Approval request and decision service under services/assurance/approvals/ plus protected actions	BG-03/BG-05	Explicit fresh-auth decision writes immutable entry/attestation/event	Tenant, RBAC, replay, transaction, stale auth and SoD tests	Disable actions; preserve entries	L	Real approvers required for live use
BG-07	Evidence-envelope service/export under services/assurance/evidence-envelopes/	BG-01/BG-06	Canonical JSON and redacted PDF share verifiable subject digest	Golden envelope, redaction, export corruption tests	Regenerate export from canonical record	M	Retention/redaction approval

BG-08	Independent verifier under services/assurance/verification/	BG-03/BG-07	Deterministic reason codes; producer separation; invalidation	33-obligation, drift, authority, qualification and verifier-conflict tests	Stop verification jobs; preserve results	L	Checker policy required
BG-09	G1 verified-manifest adapter and gate parity	BG-08	Current gate trusts only verified exact-hash evidence; legacy comparison retained	Focused G1/program tests and corrupt-manifest tests	Revert adapter selection	M	Gate owner approval
BG-10	Persistent gate/dependency/run layer under services/assurance/gates/	BG-09	Acyclic graph; correct not-evaluated/blocked/pass behavior	Dependency, idempotency and invalidation tests	Observe mode / existing scripts	L	Gate catalog approval
BG-11	Extend assurance incidents and proof trails for artifacts/approvals/gates	BG-08/BG-10	Every failed obligation creates a safe actionable blocker	Redaction, permission, reopen/resolve tests	Existing incident model remains	M	No
BG-12	Approval/authority/gate UI under existing assurance routes/components	BG-06–BG-11	State-complete EN/FR accessible workflow	Browser, accessibility, permission and error-state evidence	Feature flag UI	L	Content/accessibility review
BG-13	Notification/escalation templates using existing alert delivery	BG-11	Dedupe, expiry, escalation and safe content	Retry/dead-letter and privacy tests	Disable channels	M	Escalation policy
BG-14	Domain evidence adapter SDK and second-domain pilot	BG-10/BG-11	No direct cross-domain mutation; one selected domain reaches parity	Contract, failure and tenant tests	Remove adapter from registry	L	Domain owner selection
BG-15	Optional external-signature adapter	BG-07	Provider-neutral, verified webhooks and final evidence digests	Security/privacy/provider chaos tests	Disable provider	L	Legal/provider decision
BG-16	Enterprise hardening, runbooks and rollout gates	All prior	Restore/reconciliation/chaos/security evidence accepted	Full hardening packet	Keep observe mode	L	Yes, release authority

Proposed permissions

Permissions are proposals and require catalog review:

Code or command excerpt

```
controls.artifact.read controls.artifact.manage controls.authority.read
controls.authority.manage controls.policy.read controls.policy.manage
controls.approval.read controls.approval.decide controls.verification.read
controls.verification.execute controls.gate.read controls.gate.run
controls.evidence.export
```

Sensitive mutations require fresh authentication. Approval and verification also require the policy-specific authority, not only the general permission.

Verification strategy

Unit and contract

- 1 Canonicalization vectors and hash formats.
- 1 Policy expansion/quorum/SoD.
- 1 State transitions and invalidation.
- 1 Authority effectivity and delegation.
- 1 Evidence-envelope serialization.
- 1 Deterministic verifier reason codes.

Integration

- 1 PostgreSQL transactions, unique keys and concurrent decisions.
- 1 Audit/business-event/outbox atomicity.
- 1 Tenant isolation and cross-tenant negative cases.
- 1 Migration deployment and rollback readiness.
- 1 Worker retry and dead-letter reconciliation.

Browser/accessibility

- 1 Fresh-auth challenge and recovery.
- 1 Exact artifact/decision review before approval.
- 1 Expired, superseded, rejected and blocked states.
- 1 Keyboard-only, screen-reader, focus and bilingual content.
- 1 Permission-sensitive redaction.

Gate evidence

- 1 Current G1 contract digest.
- 1 11/33 policy expansion.
- 1 Valid and invalid evidence envelopes.
- 1 Verified-manifest digest.
- 1 G1 and POS program non-writing gate results.
- 1 Downstream NOT_EVALUATED behavior.

Operational KPIs

- 1 Median time from blocker creation to assigned owner.

- 1 Median and 95th-percentile approval-obligation age.
- 1 Percentage of obligations routed to confirmed authority on first attempt.
- 1 Verification failure rate by reason.
- 1 Artifact/policy drift invalidation rate.
- 1 Number of attempted self-approvals and cross-tenant denials.
- 1 Alert retry/dead-letter rate.
- 1 Evidence export verification success rate.
- 1 Time between authority expiry warning and remediation.

Do not use these metrics to rank or punish individual approvers. They measure process health.

Immediate next actions

- 1 Approve or amend the target architecture ADR.
- 2 Complete Phase 0 governance decisions.
- 3 Assign file ownership for BG-01 through BG-05.
- 4 Review the additive schema design before generating a migration.
- 5 Keep G1 fail closed and do not edit the frozen contract.
- 6 Begin implementation only after the authority-source and G1 policy decisions are documented.